CHECKPOINT: GOVERNANCE,COMPLIANCE AND LEGISLATION

In this checkpoint we are aiming to Identifying Browser Attack

During this checkpoint you will learn how to use burpsuite tool in order to achieve an SQL injection to retrieve data from the database and also try to achieve an SQL injection

So following the instructions in the video:

Browser Attacks using Burp Suite, focusing on SQL Injection and DOM-Based XSS vulnerabilities.

Objective:

SQL Injection: Retrieve data from a database by exploiting vulnerabilities in a web application.

DOM-Based XSS: Leverage cross-site scripting (XSS) vulnerabilities in the DOM to execute malicious code.

SQL Injection Lab: Listing Database Contents (Oracle)

Instructions for the SQL Injection Lab

Set Up Burp Suite:

Launch Burp Suite and configure your browser to use Burp's proxy.

Go to the Proxy tab in Burp Suite and ensure Intercept is On.

Launch Burp's embedded browser from Burp Suite to visit the lab website. This ensures all traffic is routed through Burp Suite for interception.

Determine Number of Columns in the Query:

In the category parameter, use the following payload to check the number of columns being

returned by the SQL query:
'+UNION+SELECT+'abc','def'+FROM+dual--

This will help you identify that two columns, both containing text, are being returned.

Retrieve List of Tables in the Database:
Use this payload to retrieve a list of all tables:
'+UNION+SELECT+table_name,NULL+FROM+all_tables--

Find the Table Containing User Credentials:
From the list of tables, identify the table that likely contains user credentials (e.g., USERS_ABCDEF).

Retrieve Column Details of the Users Table:
Use the following payload to find the columns in the USERS_ABCDEF table:

'+UNION+SELECT+column_name,NULL+FROM+all_tab_columns+WHERE+table_name='USERS_ABCDEF'--

Identify columns related to usernames and passwords.

Retrieve Usernames and Passwords:

Use the following payload to retrieve the actual usernames and passwords for all users:

'+UNION+SELECT+USERNAME_ABCDEF,+PASSWORD_ABCDEF+FROM+USERS_ABCDEF--

Log in as admin using the credentials retrieved.

DOM-Based XSS Lab: Document Write Sink

Instructions for the DOM XSS Lab:

1. Visit the Lab Website:
   Go to the URL for the DOM XSS lab: PortSwigger DOM XSS Lab.
2. Enter Random Alphanumeric String:

In the search box, enter a random alphanumeric string (e.g., test1234).

Right-click on the page and inspect the element. You will see that your string is placed inside an img tag's src attribute.

3. Break Out of the img Attribute:

To trigger the XSS attack, use the following payload to break out of the img tag's attribute and call the alert() function:
"><svg onload=alert(1)>

This will execute JavaScript and trigger the alert function, proving the existence of the DOM-based XSS vulnerability.

Summary of Approach:

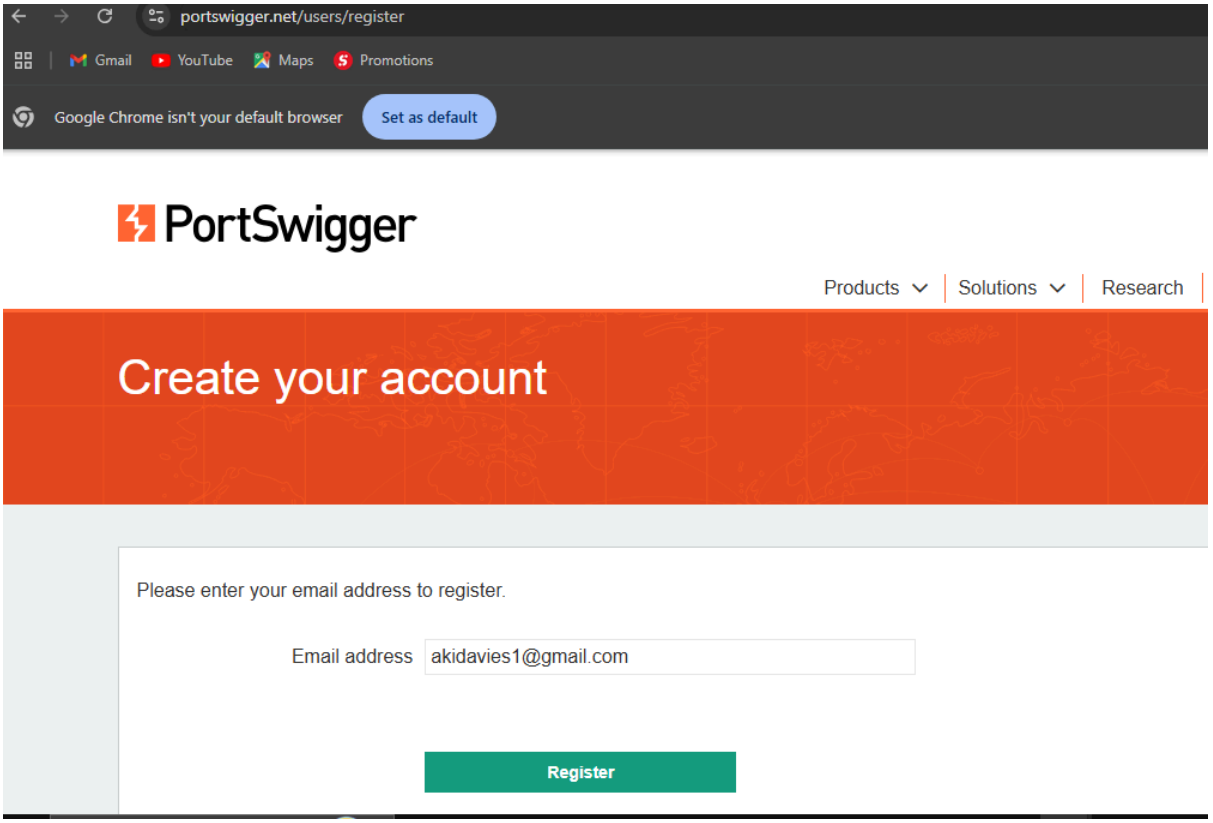
1. SQL Injection: You are exploiting the UNION SQL injection technique to retrieve sensitive data (e.g., usernames and passwords) from a vulnerable Oracle database. By manipulating SQL queries, you can bypass security mechanisms and access unauthorized information.

2. DOM-Based XSS: The vulnerability arises when untrusted data (like user input) is directly inserted into the DOM, allowing an attacker to inject and execute arbitrary JavaScript in the victim's browser. In this lab, you use the document.write() function to inject malicious code and trigger the XSS attack.

Conclusion:

Burp Suite is a powerful tool for identifying and exploiting vulnerabilities like SQL Injection and DOM-Based XSS in web applications.

Mastery of these attacks is crucial for penetration testers to understand how attackers can exploit such vulnerabilities and for security professionals to prevent these risks in their own applications.



PortSwigger

Log out MY ACCOUNT

Products | Solutions | Research | Academy | Support |

My Account

- Personal Details
- Certifications
- Subscriptions
- Order History

Your Subscriptions

BUY PROFESSIONAL

